

Reproducible Regression Harness for Machine-Learning Security Tools

Contract-Validated Adapters Catching Cross-Repo Breakage Before It Ships

Evidence status: This is a dated repository snapshot at the commit identified below. VERIFIED_AT_SNAPSHOT means verified for that commit and environment; it does not assert the same result on the latest main. Compare newer claims with the repository evidence before reuse. Can independently-developed ML security tools be held to shared output contracts so cross-repo format drift fails fast instead of silently?

73 across 9 modules

Test functions

Verified poster evidence

72 passed, 1 skipped

Current CI

Verified poster evidence

88.34%

Statement coverage

Verified poster evidence

5

Real fixtures

Verified poster evidence

gated CI

Real adapters

Verified poster evidence

100

Known-bad flagged

Verified poster evidence

100

Known-good clean

Verified poster evidence

50

Smoke scaffold (synthetic)

Verified poster evidence

Contribution

A contract-validated regression harness that wraps ML security tools in typed in-process adapters, runs them against versioned fixtures, and fails pytest on schema drift — with a hard, labeled separation between REAL product adapters and a synthetic smoke-test scaffold.

Problem & Threat Model

Chain: TOOL OUTPUT CHANGE -> DOWNSTREAM CONSUMER -> MISSING FINDINGS -> CONTRACT BOUNDARY -> PYTEST FAIL FAST.

Adversary capability: n/a — integrity/ regression risk; Assumptions: tools importable in- process; frozen fixtures; Out of scope: real-world accuracy; smoke-test scaffold numbers are synthetic; Residual risk: fixture coverage gaps; adapter staleness.

Current Verified Evidence

- VERIFIED_AT_SNAPSHOT — Real HF-scanner adapter: precision=recall=F1=1.0 on 5 fixtures — README verified real run; tests/test_hf_scanner_adapter.py end-to-end (no mock); total_tp=3,total_fp=0,total_fn=0.
- VERIFIED_AT_SNAPSHOT — 73 test functions across 9 test modules; current Python 3.12 CI recorded 72 passed, 1 skipped with 88.34% statement coverage — repository README and test tree at HEAD 155f414188954be16d90f8e14370b81e5dde318e.
- VERIFIED_AT_SNAPSHOT — JSON-schema contracts + versioned fixtures; pytest fails on drift — README how-it-works; schemas/ + contracts/ present.
- UNSUPPORTED (disclaimed by repo) — run-smoke per-category numbers — README: seeded-PRNG synthetic scaffold for plumbing, NOT measurements. Shown as synthetic only.
- UNSUPPORTED (disclaimed) — Real-world accuracy of wrapped tools — Suite validates contracts/format, not accuracy.

Honest Boundaries

- Validates contracts/format, not real-world accuracy.
- run-smoke numbers are synthetic (seeded PRNG).
- Fixture coverage is finite; gaps possible.
- Adapters can go stale if a tool changes internals.
- Real adapter gating requires sibling install.

Evidence Sources & References

[1] JSON Schema · [2] pytest · [3] OWASP ML Security · [4] MITRE ATLAS · [5] SLSA / evidence provenance · [6] NIST AI RMF 1.0

Reproducibility

Evidence: results/real_hf_scanner.json, METHODOLOGY.md, tests/